NAME: NICHOLAS ATACHA

ASSIGNMENT 3.4: INCIDENT RESPONSE AND BCP CONSULTING – TABLETOP EXERCISE
CLIENT: "GLOBAL BANK," A LARGE FINANCIAL INSTITUTION
DATE: 11 OCTOBER 2026

1. TABLETOP EXERCISE PLAN

We can't wait for a real ransomware to test if our plan works. So this exercise is to sit the executives down, walk them through a crisis, and see where we break before real customers are affected.

Objectives

The whole point is simple. I want to know 3 things:

1. Can Global Bank detect and respond fast enough before customers panic?

2. Can the business keep running even if core banking is down?

3. Do the CEO, CISO, Legal, and Comms all know their role and who makes the final call?

Scope

We will focus only on the core banking system because that's what the ransomware hit. We won't touch branches or HR systems. The exercise will run for 2.5 hours with the executive team. No real systems will be shut down. This is discussion only.

Participants

The exercise requires key decision-makers in the room: CISO, CIO, CEO, CFO, COO, Head of Legal/Compliance, Head of Corporate Communications, Head of Risk, and Head of Customer Experience. I will act as the facilitator to drive the scenario forward.

The Scenario

It's Monday at 8:30 AM. Customers cannot access the mobile app, USSD, or ATM services. The Security Operations Center (SOC) identifies that the core banking database is encrypted. A ransom

note pops up demanding 200 BTC. At the same time, Twitter is already saying "Global Bank is down". We have 72 hours before the attackers threaten to leak customer data.

Injects

I introduced events in stages to test decisions under pressure.

1. Inject 1 - T+0: "Core banking is offline. Ransom note found. What's your first 3 actions?"

Testing: Incident declaration

2. Inject 2 - T+30min: "This is now trending on X. Customers are angry. CBN is calling. What do we tell them?"

Testing: Crisis communication

3. Inject 3 - T+1hr: "Attackers emailed CFO directly offering 50% discount if paid in 12hrs. Backup team says last good backup is 2 days old."

Testing: Ransom decision, RPO/RTO, BCP activation

4. Inject 4 - T+2hr: "Forensics found it started from a phishing email to HR. Do we shut down email for everyone?"

Testing: Containment vs Business impact

2. HOW I FACILITATED & KEY DISCUSSIONS

I ran the session like a real incident. No slides. Just the scenario and pressure.

Discussion 1: Do we pay?

There was pressure to pay because of the ₦500M/day loss estimate. But CEO and Legal agreed: paying funds criminals and CBN/NDPC will have issues with it. Decision: Do not pay. Go the recovery route.

Discussion 2: What do we tell customers?

Comms and CX argued for 20 minutes. We agreed on honesty but calm. Decision: Send SMS/Email within 1 hour: "We are experiencing a technical issue. Your funds and data are safe. We will update you every 2 hours."

Discussion 3: Business Continuity

COO said we can't wait 18hrs for restore. Decision: Activate manual teller processes for salary and critical payments at major branches. Accept the risk and document it.

Discussion 4: Regulators

Legal reminded us of CBN Cyber Guidelines and NDPA 2023. Decision: Formal notification to CBN and NDPC within 4 hours, even before we fully understand the scope.

3. LESSONS LEARNED & RECOMMENDATIONS

After the exercise, 4 major gaps came out.

Gaps Identified:

1. Our backups are a problem. 48 hours of data loss is not acceptable for a bank. We also never tested restoring them.

2. We have no holding statement. We wasted 30 minutes arguing on what to tell customers.

3. People are still the weakest link. Phishing got us in. Training is just a compliance checkbox.

4. Roles in a crisis are blurry. Everyone was looking at the CISO to make business decisions.

Recommendations:

1. Move to immutable daily backups and do a restore test every quarter. Target RPO of 4 hours max.

2. Create a Cyber Crisis Comms Kit today. 3 pre-approved templates for customers, media, and regulators.

3. Run phishing simulations every month and tie results to KPIs for department heads.

4. Update the IRP with a one-page "Who decides what" chart and do this exercise again in 6 months.

Conclusion

Global Bank has a good IRP on paper. But paper doesn't stop ransomware. This exercise showed we would survive, but with major reputation and financial damage. The fixes above are not expensive. They are about discipline.